Sequence diagram — authentication (2/2): access-token refresh

Front end · React

- Any page
- api (client.ts)

Back end · NestJS

- JwtAuthGuard
- AuthController
- «service» AuthService
- «repository» PrismaService

Data

- PostgreSQL

1 GET /bookings

2 Bearer <expired access token>

3 401 Unauthorized

4 refreshAccessToken()

one refresh at a time, request not yet retried

5 POST /auth/refresh-token

6 refreshToken(refreshTok)

7 jwtService.verify(refreshTok)

8 userSession.findFirst({ id: sessionId, refresh_token })

9 SELECT user_sessions

break [session revoked, or token already rotated]

10 UnauthorizedException

11 401

12 clearAuthStorage(), back to /login

13 generateTokens({ userId, sessionId })

14 userSession.update({ refresh_token })

15 UPDATE user_sessions

16 { accessToken, refreshToken }

17 200 OK

18 writeTokens(accessToken, refreshToken)

19 retry GET /bookings with the new token

20 200 OK

21 bookings